Security Concepts
Part II

Topics

- Security Controls
  - Category of controls
  - Types of controls
- Governance Elements
  - Regulations and Laws
  - Standards
  - Policies
  - Procedures
- Code of Ethics
  - $(ISC)^2$
  - Computer Ethics
  - IEEE
  - IEEE CS/ACM
- Glossary

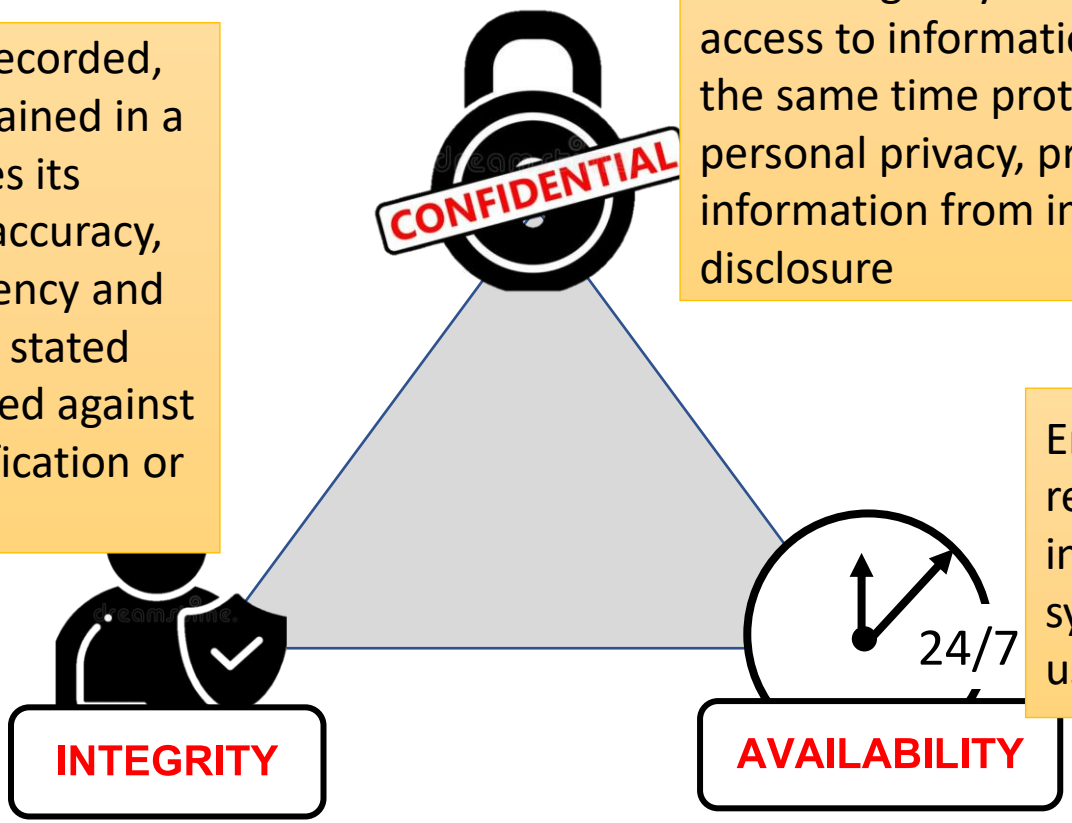
Some of the material and exercise are adapted from $(ISC)^2$ training material.

The CIA Triad Recap

- The common objectives for security are well-known as the CIA triad.

Information is recorded, used and maintained in a way that ensures its completeness, accuracy, internal consistency and usefulness for a stated purpose. Guarded against improper modification or destruction.

Permitting only authorized access to information, while at the same time protecting personal privacy, proprietary information from improper disclosure



Ensure timely and reliable access of information and system by authorized users.

Computer Security Challenges

- Not only CIA but also CIANA-PS (Non-repudiation, Authentication, Privacy and **Safety**)
- Not simple, very difficult to reach security goals.
- Involve multiple parts such as algorithm, protocols, devices, users, procedures, etc.
- Difficult to predict where and when the attack will happen.
- Require enormous efforts to monitor and maintain security stature
- Most of the time, it comes as an afterthought.
- Outright rejection or resistance from users for economic or efficiency reasons.

Threats to CIA

In these scenarios, discuss in your group what could go wrong ?

- Coworker sharing passwords to help get things done.
- Laptop of remote worker being left unattended or unlocked at home with children.
- Long-term power outage that cause the backup generator to run for a long period of time.
- Improper fire suppression methods in the data center.

Security Controls

Controls or Countermeasures

The management, operational and technical controls (i.e. safeguards or countermeasures) prescribed for an information system to protect the confidentiality, integrity and availability of the system and its information. FIPS PUB 199

- The implementation of controls should reduce risk, hopefully, to an acceptable level.

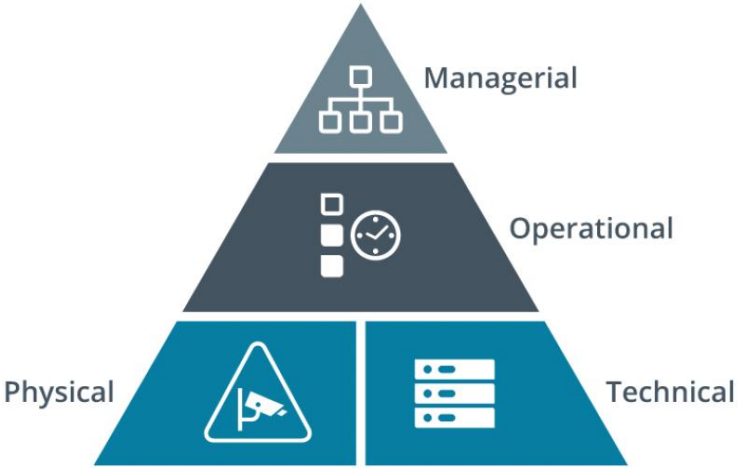
More on Countermeasures

- The cost of the countermeasure should be less than the value of the asset.
- The result of the applied countermeasure should make the cost of an attack greater for the perpetrator than the derived benefit from an attack.
- The countermeasure should provide a solution to a real and identified problem.
- The benefit of the countermeasure should be testable and verifiable.
- The countermeasure should provide uniform protection across all users, systems, protocol and so on.
- The countermeasure should be tamperproof.
- The countermeasure should provide fail-safe and/or faill-secure option.

Security Controls Category

Security Control Categories

- Managerial
  - Give oversight of system
- Operational
  - Relies on a person for implementation
- Technical
  - Implemented in operating systems, software, and security appliances
- Physical
  - Devices that mediate access to premises and hardware

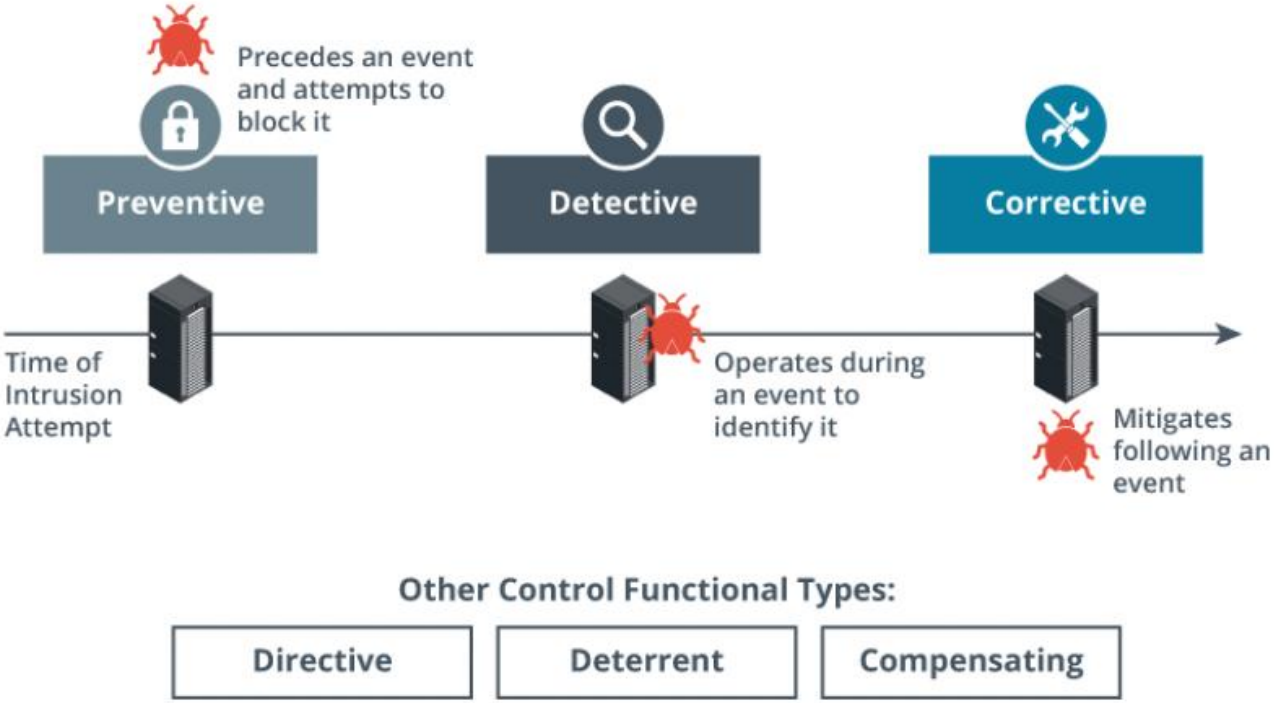


Security Controls Category

Security controls, countermeasures, and safeguard can be implemented using one of these 4 mechanism (according to ISO27002:2022)

- Physical: physical (tangable) hardware devices e.g. locks, cable protection, walls, fences, moats, lights, sealed windows, security guard, dogs, motion detector, badges, swipe cards, VDO cameras, alarms. Controlling movement of people and equipment in specific location. Most situation supported by technical controls for overall security system. Example: visitors vs. employees facility access
- Technical (or Logical): executed by computer or information systems providing automated protection. Can be configuration settings or parameters stored as data. E.g. authen methods, encryption, access control lists, protocols, firewalls, routers, IDSs.
- People: aimed at the individuals within the organization, e.g. screening, employment term, awareness training, discipline, termination, NDA, remote working, security event reporting.
- Organizational: directives, guidelines, procedures needed to be established and integrated to task-level activities. Usually enforced with physical, technical or people controls, e.g. security policy, roles & responsibilities, segregation of duty, threat intelligence, access control, identity management, data classification, work supervision, supplier management, protection of PII, review and compliance.

Types of Controls



Types of Controls

An action, device, procedure, or technique that meets or opposes (i.e., counters) a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken. (from RFC 4949) (Refer NIST SP800-53)

A control (physical, technical or administrative) is designed to achieve one or several purposes or types.

- Preventive controls - thwart or stop unwanted activitiy from occurring.
- Deterrent controls - discourage security policy violation
- Detective controls – discover or detect unwanted activity
- Compensating controls - provide options to existing controls
- Corrective controls – modify the environment to return to normal after a security incident.
- Recovery controls – repair or restore resources after more damaging events.
- Directive controls – direct, confine or control the actions of subjects to encourage compliance, e.g. requirements, notifications, guidances, signs..

Type of Control Examples

Preventive Controls

Physical

- mantrap locks, access control vestibules,
- Alarm systems, guards, dogs

Technical

- Authentication
- Access control methods
- Data loss prevention (DLP)
- Encryption
- Anti-malware software
- Firewalls, Intrusion prevention systems (IPS)

Administrative

- Separation of duties, Job rotation
- Penetration testing
- Auditing
- Security policies
- Security awareness training

Deterrent Controls

Very similar to preventive but different purpose

Physical

- Locks, fences, security badges, guards, access control vestibules, security camara, warning signs

Technical

- Authentication
- Access control methods
- Data loss prevention (DLP)
- Encryption
- Anti-malware software
- Firewalls, Intrusion prevention systems (IPS)

Administrative

- Policies, security awareness training

Examples Types of Controls

Preventive

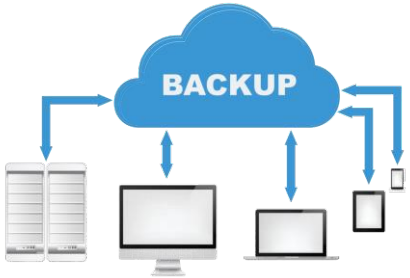
- Hardening
- Security awareness and training
- Security guards
- Change management
- Account disablement policy

Detective

- Log monitoring
- Trend analysis
- Security audit
- Recording and reviweing of video camera
- IDSs
- Job rotation, mandatory vacation

Compensating

- E.g. use TOTP instead of smart card temporarily, DRP



Recovery

- Backups and restores
- System imaging
- Server clustering
- Hot, warm, cold sites.

Deterrent

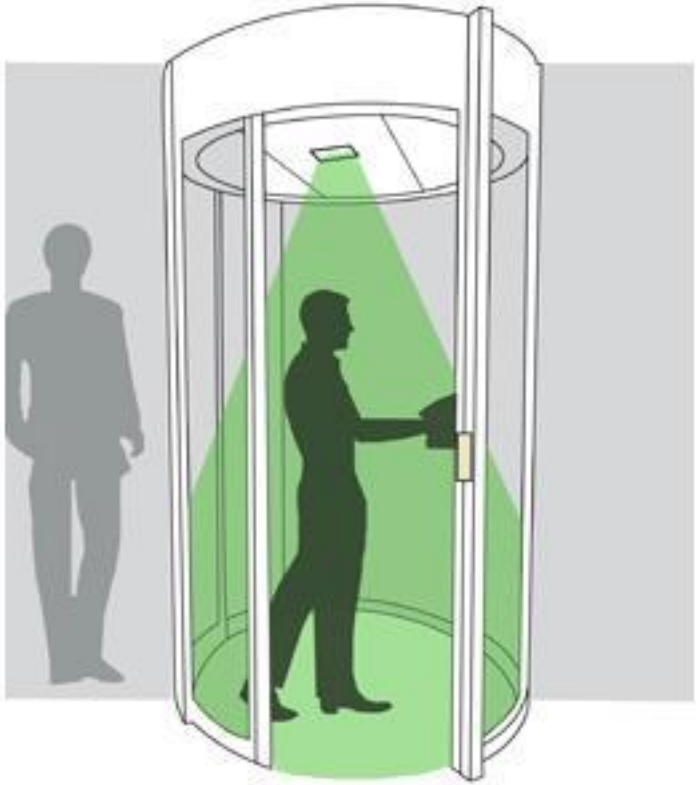
- Some preventive controls
- Cable locks, locks
- Fence

Corrective

- Malware removal
- IPS (Intrusion Prevention System)
- Fixing files or physical controls

What about this ?

What about this ?



What about this ?

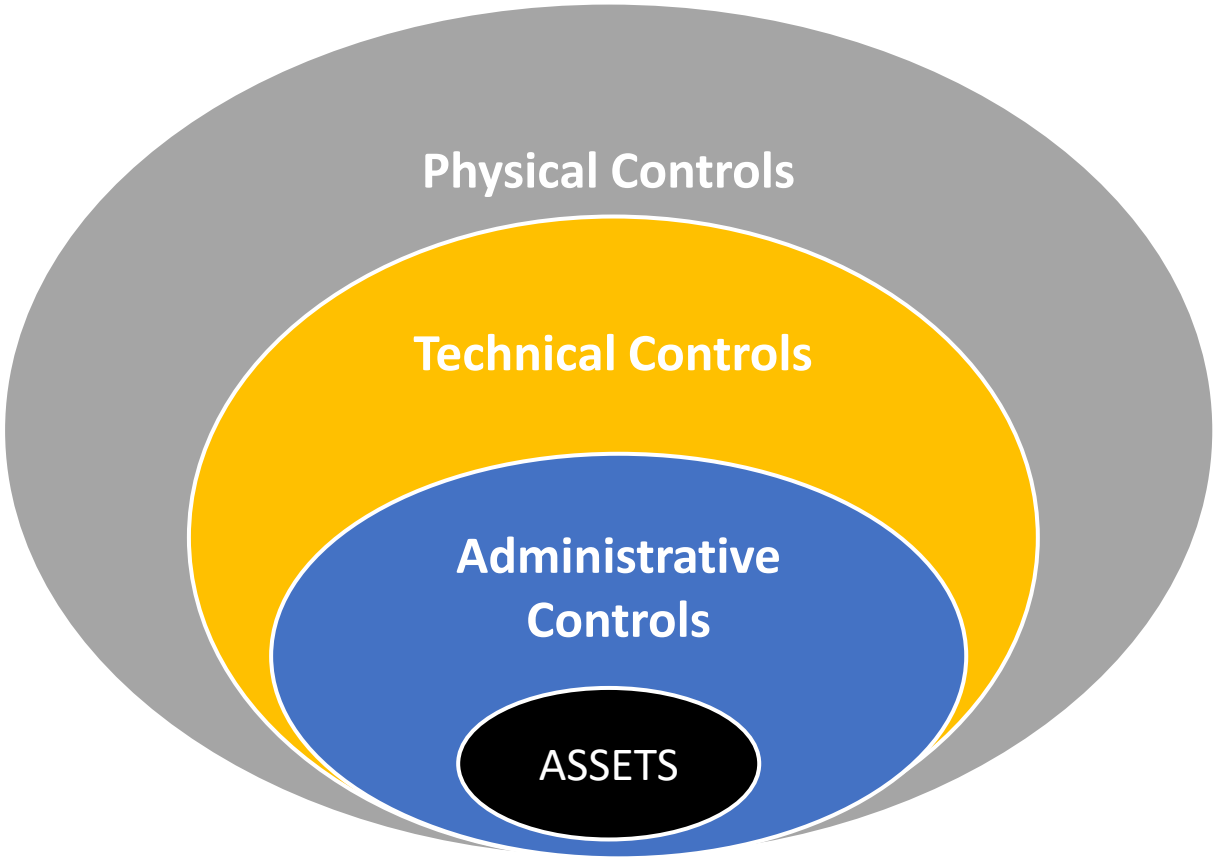
Which control category ? control types ? CIA objectives ?

Defense-in-Depth

There are no perfect security controls. They all have issues and vulnerabilities

- can be turned off
- may be avoided
- can be bypassed
- can be overloaded
- can be tricked by impersonation
- may have backdoors
- can be misconfigured

This imperfection is addressed by using defense-in-depth strategy



Defense in Depth

Organizations should use of multiple, overlapping security controls to achieve each of their security objectives.

Eavesdropping

- Encryption through virtual private networks
- Encryption at the application layer
- Segmentation with VLANs

Access Control

- Network access control
- Role-appropriate VLANs
- MAC filtering
- Port security

Network Perimeter

- Firewall
- Router access control list
- Intrusion Prevention System

System failure

Governance Elements

Security Governance

Security governance – practices related to supporting, evaluating, defining and directing the security efforts of an organization.

- Optimally performed by a board of directors but affect all levels, not just security or IT function
- Goals – to maintain business processes while striving toward growth and resiliency – security is a business operation issue
- Could be under the influence of legislative and regulatory compliance, industry guidelines and license requirements

Managing Security Functions

Security function – focuses on the task of evaluating and improving security over time

- To manage security function, organization must implement proper and sufficient security governance, e.g risk assessment drives security policy
- Security must be measurable to determine completeness and effectiveness of a security program
- Security management planning creates, implements and enforces security policy that aligns strategy, goals and missions of organization
- Top-down approach is the most effective way
  - Senior management -> security policies
  - Middle management -> standards, baseline, guidelines, procedures
  - Security professionals-> implement as documented
  - End users -> comply with all security policies

Governance Elements

(In reverse order)

- เครื่องยนต์ Procedures – detailed steps to complete a task that support departmental or organizational policies
- หางเสือเรือ Policies – put in place by organizational governance, such as executive management to provide guidance in all activities to ensure that the orgazniation suports industry standards and regulations.
- Standards – often used by governance teams to provide a framework to introduce policies and procedures in support of regulations.
- Regulations – commonly issued in the form of laws usually from government and typically carry financial penalties for noncompliance.

Regulations and Laws

- Imposed by governments at the national or regional or local level with associated fines.
- Examples:
  - US Health Insurance Portability and Accountability Act (HIPAA) of 1996
    - Governs the user of protected health information (PHI) in the US.
    - Violation may result in fines and/or imprisonment for both individuals and companies

      คุ้มครองส่วนบุคคล เป็นต้นแบบในการปรับใช้ทำ pdpa
  - EU General Data Protection Regulation (GDPR) of 2016
    - Enacted by the European Union to control the use of peronally identifiable information (PII) of its citizens and those in the EU

      ไม่คุ้มครองคนตายแล้ว ยกเว้นสิงคโปร์ ยังคุ้มครองอีก 10ปี
    - Financial penalties to companies even outside the EU (4 times the global revenues)
  - TH Personal Data and Privay Act (PDPA)

    ของไทยแทบลอก GDPRมาเลย แต่มากำหนดเพิ่ม
    - Enacted by Thailand 1 June 2022

      เรื่องโทษ ex จำคุก
    - Violation can result in fines and/or imprisonment
  - TH Cybersecurity Act (2019) ปรับให้สอดคล้อง famework ของอเมริกา
  - EU's Cyber Resilience Act (2024)
  - Can you think of any other laws that impact businesses

Standards

- Standards have been developed to cover management practices and the overall architecture of security mechanisms and services
- Organizations use multiple standards as both compliance documents and advisories or guidelines.

  ex มีกำหนดบอกว่าต้องแจ้งภายในเท่าไหร่ หลังจากทำข้อมูลรั่ว ไม่งั้นจะโดนโทษ น่าจะต้องแจ้งภายใน 72ชม
- The most important of these standard body organizations are:
  - National Institute of Standards and Technology (NIST)
    - FIPS PUB 200, SP 800-100
  - Internet Society (ISOC) – especially IETF
    - RFC-2196
    - Kerberos, IPSec, X.509, S/MIME, TLS
  - International Telecommunication Union (ITU-T)
    - X.800, X.810
  - International Organization for Standardization (ISO)
    - ISO 27001-2,
    - ISO 15408 (Common Criteria - Computer Security Certification)
  - International Electronic Commission (IEC)
  - China Information Security Standardization Technical Committee
    - Graded Protection of Information Security (GB)

Policies

- Directed by applicable law(s)
- Specifies which standards and guidelines will be followed
- Broad, not detailed, giving context and providing strategic direction
- Many levels and types of policies
  - Governance Policy – control decision-making processes
  - Security Policy – defines scope of security needs, assets to be protected, strategic security objectives, visions and goals, responsibilities, roles and audit requirements.
  - System specific security policy – focuses on individual system.
  - Acceptable Use Policy (AUP) – defines a level of acceptable performance and expectation of behavior and activity, applied to all users of the information system.

From Policies to Procedures

iso 27001 **เป็นคนออกกฎ**

- Once the main security policies are set, the following set of accompanying security documentation can be crafted
  - Standards – compulsory requirements for the homogenous use of hardware, software, technology and security controls.
  - Baselines – minimum level of security that every system must meet. Usually very system specific and refers to industry or government standard.
  - Guidelines – recommendations on how standards and baselines are implemented, serves as operational guide, flexible and customizable for each unique system and condition, not compulsory.
  - Security Procedure or Standard Operating Procedure (SOP) – detailed, step-by-step how-to document necessary to accomplish a specific task or sets of tasks (one-time, infrequent actions or regular tasks). Define how tasks are successfully completed. Employees must be trained to locate and follow these SOPs.
    - Examples: Setting up new workstation, perform backups, etc.

Example standards, frameworks, reference architectures

ISO 27000 ISMS Family of Standards

Requirements

Controls

I	II	III	IV
Requirements and supporting guidelines	Audit and certification guidelines	Industry information security management requirements	Health information security management standards
ISO/IEC 27000	ISO/IEC 27006	Finance	ISO 27799
ISO/IEC 27001			
ISO/IEC 27002	ISO/IEC 27007	Telecommunication	Projects that are in the research phase. For example, medicine supply chain and storage security.
ISO/IEC 27003			
ISO/IEC 27004	ISO/IEC 27008	Other specific security domains	
ISO/IEC 27005			

quote of practice **แนวทางการปฏิบัติ**

Control areas in ISO 27002

ISO/IEC 27002:2013	ISO/IEC 27002:2022 ปจบ
Information technology — Security techniques — Code of practice for information security controls	Information security, cybersecurity and privacy protection — Information security controls
14 control categories	4 themes & 5 attributes คุมสิทธิ์, job role - personal control
114 controls	93 controls

Basic Technical Requirements

- Each grade of protection has corresponding technical requirements. For example, the technical requirements for Grade III cover 5 aspects:

Physical security | App security | Data security | Network security | Host security

- 7 control points and 33 items:

1. Structure security (7 items)
2. Access control (8 items)
3. Security audit (4 items)
4. Boundary integrity check (2 items)
5. Intrusion prevention (2 items)
6. Malicious code program (2 items)
7. Network device protection (8 items)

ไม่ต้องทำทุก controls เลือกทำเฉพาะ สิ่งที่เจอความผิดปกติ (จากการประเมินความผิดปกติ) หรืออยากควบคุมเป็นพิเศษ

NIST Security Requirements FIPS 200

Minimum Security Requirements for Federal Information and Information Systems

The security-related areas include: (i) access control; (ii) awareness and training; (iii) audit and accountability; (iv) certification, accreditation, and security assessments; (v) configuration management; (vi) contingency planning; (vii) identification and authentication; (viii) incident response; (ix) maintenance; (x) media protection; (xi) physical and environmental protection; (xii) planning; (xiii) personnel security; (xiv) risk assessment; (xv) systems and services acquisition; (xvi) system and communications protection; and (xvii) system and information integrity.

ข้อสอบอาจจะถาม control **ที่ใช้ ใน** security requirement

AccessControl(AC): Organizations must limit information system access to authorized users,processes acting on behalf of authorized users, or devices (including other information systems) and to the types of transactions and functions that authorized users are permitted to exercise.

AwarenessandTraining(AT): Organizationsmust:(i)ensurethatmanagersandusersoforganizational information systems are made aware of the security risks associated with their activities and of the applicable laws, Executive Orders, directives, policies, standards, instructions, regulations, or procedures related to the security of organizational information systems; and (ii) ensure that organizational personnel are adequately trained to carry out their assigned information security-related duties and responsibilities.

https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.200.pdf

NIST Security Controls FIPS 800-53

Security and Privacy Controls for Information Systems and Organizations

Access Control Family

AC-1: Policy and Procedures
AC-2: Account Management
AC-3: Access Enforcement
AC-4: Information Flow Enforcement
AC-5: Separation of Duties
AC-6: Least Privilege
AC-7: Unsuccessful Logon Attempts
AC-8 : System Use Notification
AC-9: Previous Logon Notification
AC-10: Concurrent Session Control
AC-11: Device Lock
AC-12: Session Termination
AC-13: Supervision and Review-Access Control
AC-14: Permitted Actions without Identification or Authentication
AC-15: Automated Marking
AC-16: Security and Privacy Attributes
AC-17: Remote Access
AC-18: Wireless Access
AC-19: Access Control for Mobile Devices
AC-20 Use of External Systems
AC-21: Information Sharing
AC-22: Publicly Accessible Content
AC-23: Data Mining Protection
AC-24: Access Control Decisions
AC-25: Reference Monitor

TABLE C-1: ACCESS CONTROL FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AC-1	**Policy and Procedures**	o	√
AC-2	**Account Management**	o	
AC-2(1)	AUTOMATED SYSTEM ACCOUNT MANAGEMENT	o	
AC-2(2)	AUTOMATED TEMPORARY AND EMERGENCY ACCOUNT MANAGEMENT	s	
AC-2(3)	DISABLE ACCOUNTS	s	
AC-2(4)	AUTOMATED AUDIT ACTIONS	s	
AC-2(5)	INACTIVITY LOGOUT	o/s	
AC-2(6)	DYNAMIC PRIVILEGE MANAGEMENT	s	
AC-2(7)	PRIVILEGED USER ACCOUNTS	o	
AC-2(8)	DYNAMIC ACCOUNT MANAGEMENT	s	
AC-2(9)	RESTRICTIONS ON USE OF SHARED AND GROUP ACCOUNTS	o	
AC-2(10)	SHARED AND GROUP ACCOUNT CREDENTIAL CHANGE	W: Incorporated into AC-2k.	
AC-2(11)	USAGE CONDITIONS	s	
AC-2(12)	ACCOUNT MONITORING FOR ATYPICAL USAGE	o/s	
AC-2(13)	DISABLE ACCOUNTS FOR HIGH-RISK INDIVIDUALS	o	
AC-3	**Access Enforcement**	s	
AC-3(1)	RESTRICTED ACCESS TO PRIVILEGED FUNCTIONS	W: Incorporated into AC-6.	
AC-3(2)	DUAL AUTHORIZATION	s	
AC-3(3)	MANDATORY ACCESS CONTROL	s	
AC-3(4)	DISCRETIONARY ACCESS CONTROL	s	
AC-3(5)	SECURITY-RELEVANT INFORMATION	s	
AC-3(6)	PROTECTION OF USER AND SYSTEM INFORMATION	W: Incorporated into MP-4 and SC-28.	
AC-3(7)	ROLE-BASED ACCESS CONTROL	o/s	
AC-3(8)	REVOCATION OF ACCESS AUTHORIZATIONS	o/s	
AC-3(9)	CONTROLLED RELEASE	o/s	

Frameworks & Reference Architectures

1

Security Frameworks

A collection of standards and practices designed to form a solid approach to information security

2

Reference Architectures

A description of the specific controls that would achieve an organization's security objectives

NIST Security Framework

https://www.nist.gov/cyberframework

Function Unique Identifier	Function	Category Unique Identifier	Category
ID	Identify	ID.AM	Asset Management
		ID.BE	Business Environment
		ID.GV	Governance
		ID.RA	Risk Assessment
		ID.RM	Risk Management Strategy
		ID.SC	Supply Chain Risk Management
PR	Protect	PR.AC	Identity Management and Access Control
		PR.AT	Awareness and Training
		PR.DS	Data Security
		PR.IP	Information Protection Processes and Procedures
		PR.MA	Maintenance
		PR.PT	Protective Technology
DE	Detect	DE.AE	Anomalies and Events
		DE.CM	Security Continuous Monitoring
		DE.DP	Detection Processes
RS	Respond	RS.RP	Response Planning
		RS.CO	Communications
		RS.AN	Analysis
		RS.MI	Mitigation
		RS.IM	Improvements
RC	Recover	RC.RP	Recovery Planning
		RC.IM	Improvements
		RC.CO	Communications

สำคัญ -ถ้า iden ไม่ถูก
ไม่ชัดเจน
ขั้นอื่นมันก้จะไม่ถูก

Table 2: Framework Core กฎของนี้ อิงมาจากข้อไหนบ้าง

Function	Category	Subcategory	Informative References
IDENTIFY (ID)	**Asset Management (ID.AM):** The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy.	**ID.AM-1:** Physical devices and systems within the organization are inventoried	**CIS CSC** 1 **COBIT 5** BAI09.01, BAI09.02 **ISA 62443-2-1:2009** 4.2.3.4 **ISA 62443-3-3:2013** SR 7.8 **ISO/IEC 27001:2013** A.8.1.1, A.8.1.2 **NIST SP 800-53 Rev. 4** CM-8, PM-5
		ID.AM-2: Software platforms and applications within the organization are inventoried	**CIS CSC** 2 **COBIT 5** BAI09.01, BAI09.02, BAI09.05 **ISA 62443-2-1:2009** 4.2.3.4 **ISA 62443-3-3:2013** SR 7.8 **ISO/IEC 27001:2013** A.8.1.1, A.8.1.2, A.12.5.1 **NIST SP 800-53 Rev. 4** CM-8, PM-5
		ID.AM-3: Organizational communication and data flows are mapped	**CIS CSC** 12 **COBIT 5** DSS05.02 **ISA 62443-2-1:2009** 4.2.3.4 **ISO/IEC 27001:2013** A.13.2.1, A.13.2.2 **NIST SP 800-53 Rev. 4** AC-4, CA-3, CA-9, PL-8
		ID.AM-4: External information systems are catalogued	**CIS CSC** 12 **COBIT 5** APO02.02, APO10.04, DSS01.02 **ISO/IEC 27001:2013** A.11.2.6 **NIST SP 800-53 Rev. 4** AC-20, SA-9
		ID.AM-5: Resources (e.g., hardware, devices, data, time, personnel, and software) are prioritized based on their classification, criticality, and business value	**CIS CSC** 13, 14 **COBIT 5** APO03.03, APO03.04, APO12.01, BAI04.02, BAI09.02 **ISA 62443-2-1:2009** 4.2.3.6 **ISO/IEC 27001:2013** A.8.2.1 **NIST SP 800-53 Rev. 4** CP-2, RA-2, SA-14, SC-6
		ID.AM-6: Cybersecurity roles and responsibilities for the entire workforce and	**CIS CSC** 17, 19 **COBIT 5** APO01.02, APO07.06, APO13.01, DSS06.03

top-down

vs

bottom-up

NIST Security Framework 2.0 (draft)

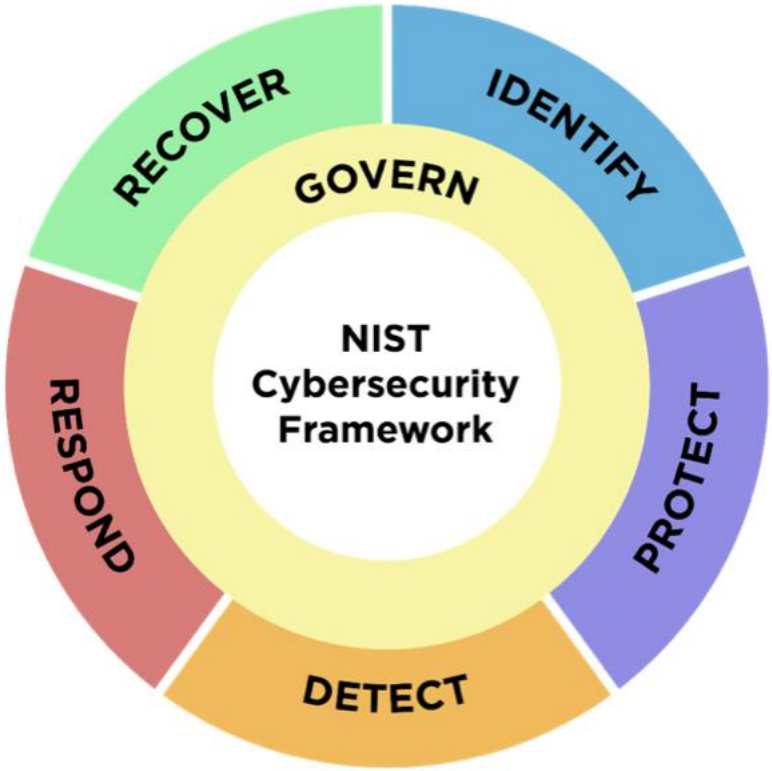


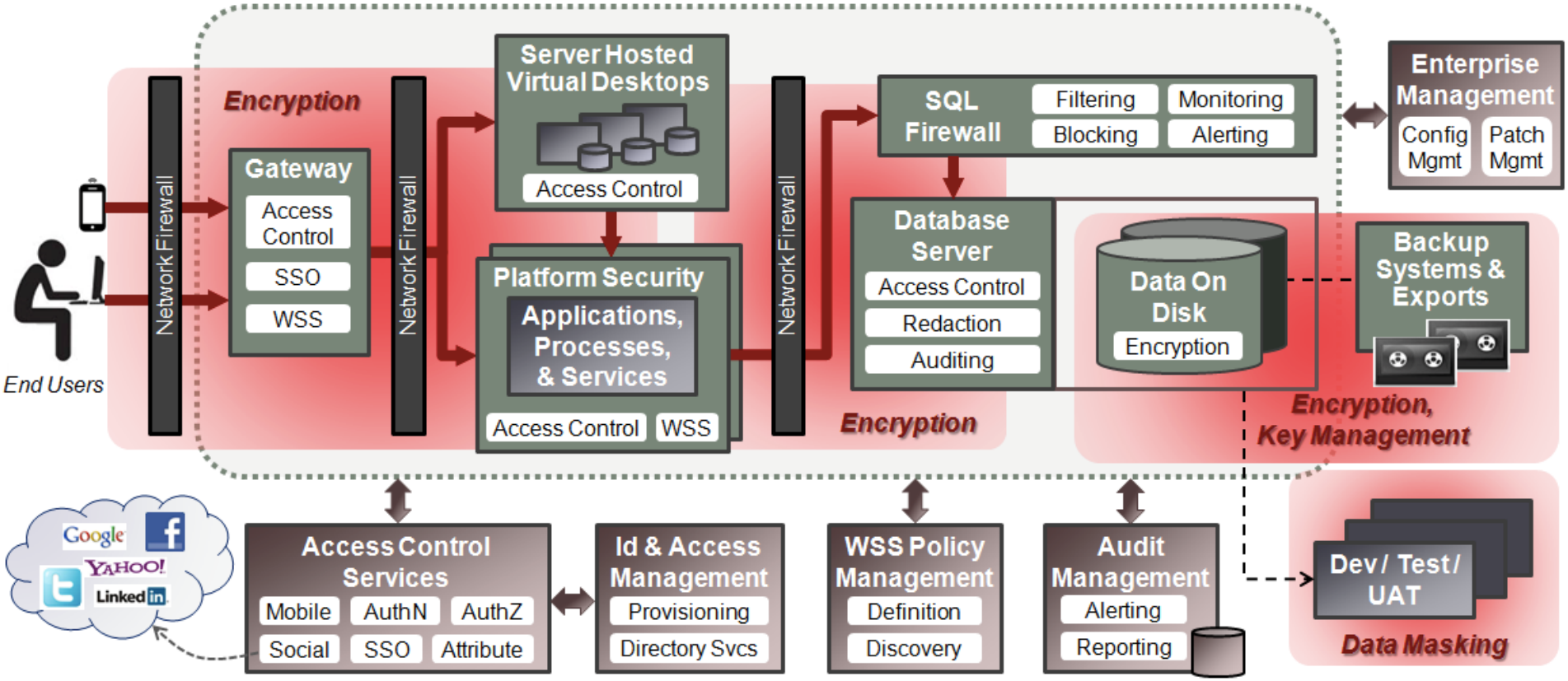
Fig. 2. Framework Functions

Table 4. CSF 2.0 Core Function and Category Names and Identifiers

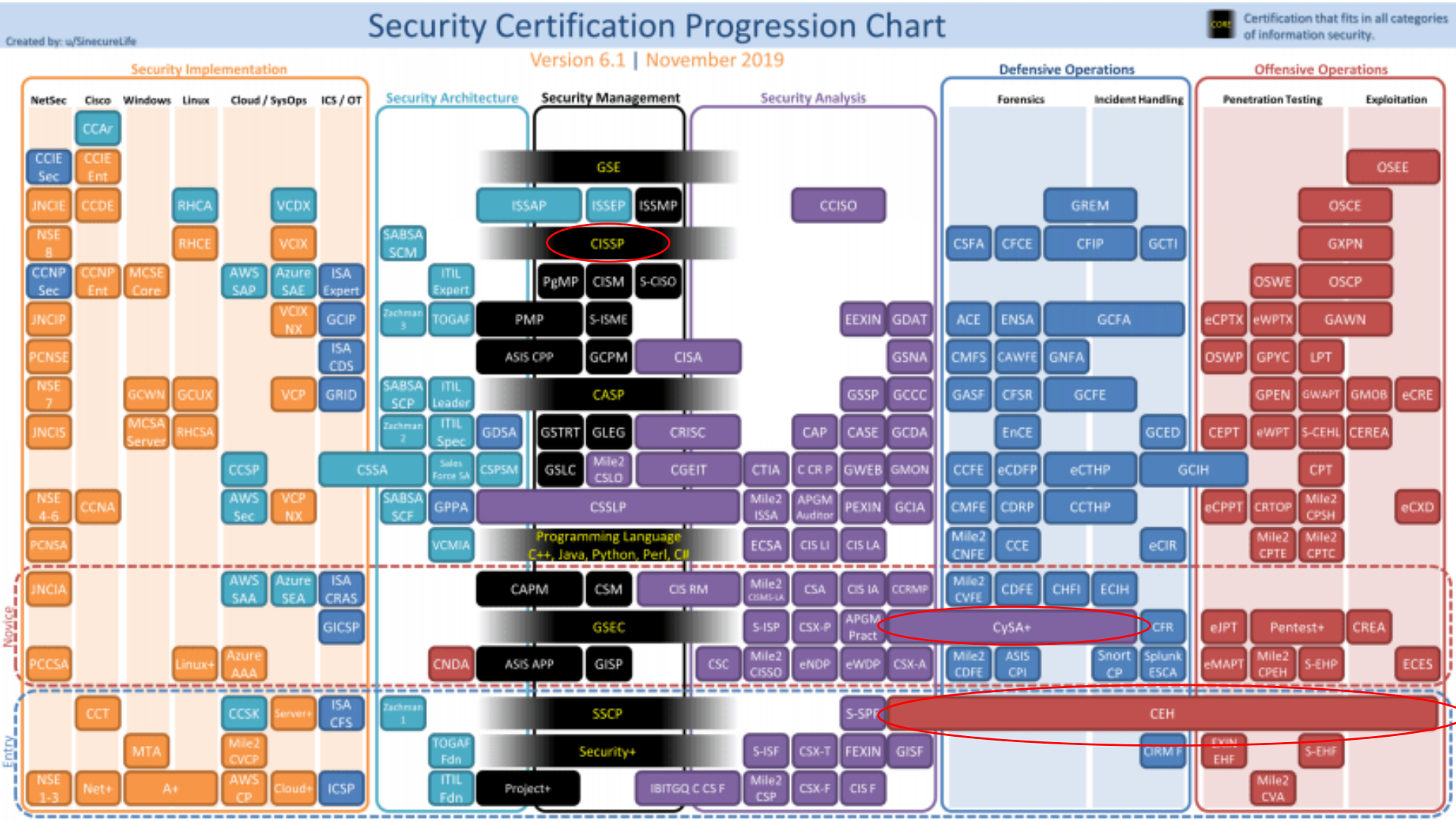
Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Cybersecurity Supply Chain Risk Management	GV.SC
	Roles, Responsibilities, and Authorities	GV.RR
	Policies, Processes, and Procedures	GV.PO
	Oversight	GV.OV
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.ipd.pdf

Oracle Reference Architecture



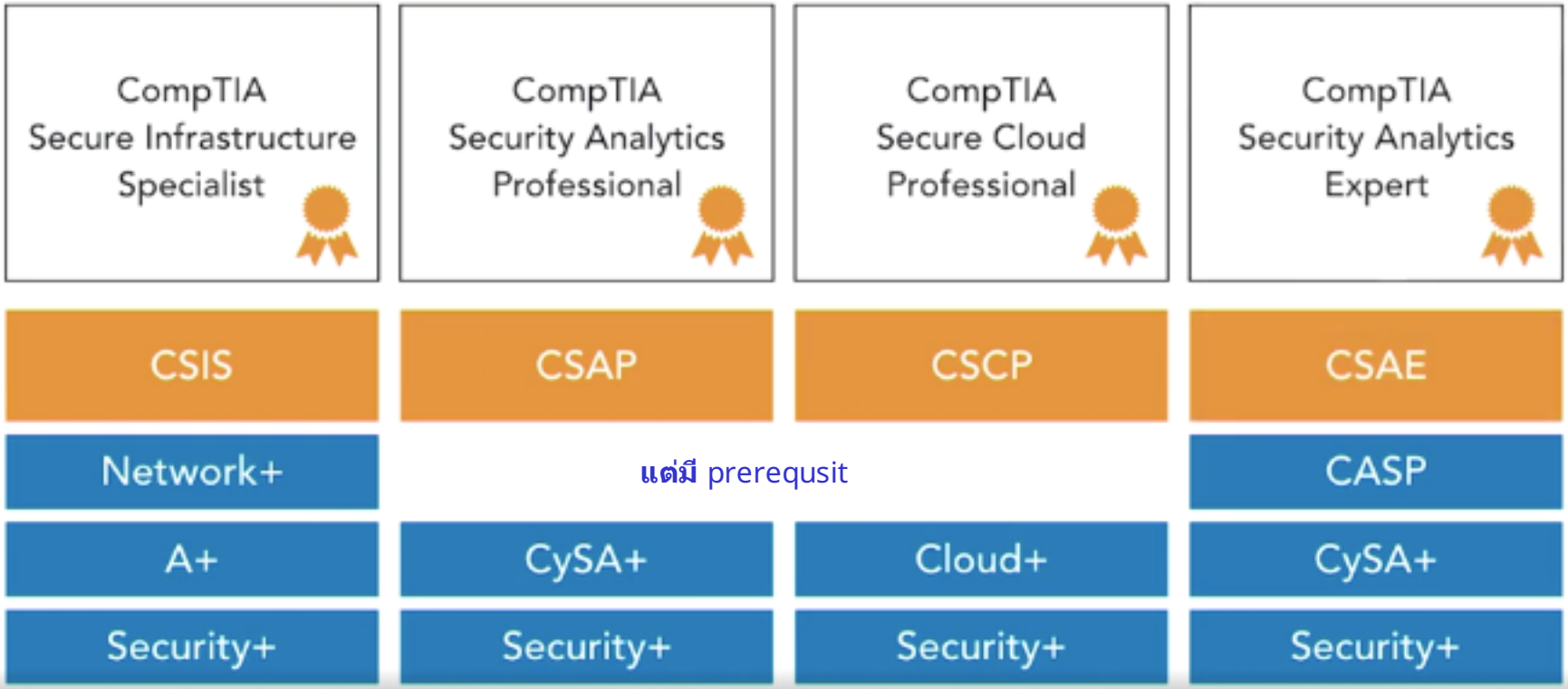
Certifications



CompTIA Stackable Certifications

cert อีกยี่ห้อนึง -expert

This course tries to follow Security+ (SY0-501) requirements. However, those who want to get the certificate must continue studying on their own.



Ethics

Ethics

จรรยาบัญ การรักษาความลับ

- Security professionals are usually entrusted with sensitive information.
- They must hold themselves and each other to a high standard of conduct.
- The rules of ethics are moral codes that guide day-to-day activities.
- “Ethos” – way of living. Ethics – philosophy that concerns about study of what’s morally right or wrong, just or unjust
- Example: business ethics describe which business actions are appropriate and just, it convers financial dealings, conflict of interest, nondiscrimination, and social responsibility.
- Ethic rules are not laws – but minimum standards for professional behavior. They provide a basis for sound, ethical judgment regardless of area of specialty or employer.

Organizational Code of Ethics

- Almost every organization has its own code of ethics.
  - Either defined officially or embodied in policies and procedures
- Example: U.S. government has Code of Ethics for Government Service as a federal law in 1980. It says that any person in government service should:
  - Put loyalty to the highest moral principles and to country above loyalty to persons, party, or Government department
  - Uphold the Constituion, laws, and regulations of the United Sttes and of all governments therein and never be a party to their evation.
  - Give a full day's labor for a full day's pay; giving earnest effort and best thought to the performance of duties
  - Seek to find and employ more efficient and economical ways of getting taks accomplished.
  - Never discriminate unfairly by the dispensing of special favors or privileges to anyone, …
  - Make no private promises of any kind binding upon the duties of office…
  - …

$(ISC)^2$ Code of Ethics

- Apply to those holding $(ISC)^2$ certificates such as CISSP, SSCP, etc.
- Preamable มีส่วนช่วยการป้องกันภัยในสังคม (รับผิดชอบต่อสังคม)
  - The safety and welfare of society and the common good, duty to our principals, and to each other, requires that we adhere, and be seen to adhere, to the highest ethical standards of behavior.
  - Therefore, strict adherence to this Code is a condition of certification.
- Canons หลักการย่อ ออกสอบ cert มีอายุ 3ปี ต้องเรียนรู้ต่อเพิ่มเติม
  1. Protect society, the common good, necessary public trust and confidence, and the infrastructure.
  2. Act honorably, honestly, justly, responsibly and legally.
  3. Provide diligent and competent service to principals.
  4. Advance and protect the profession.
- Note on different target stakeholders in each canon.

Other Code of Ethics (1)

RFC 1087 “Ethics and the Internet” by the Internet Architecture Board (IAB) – unacceptable and unethical activity are

- Seeks to gain unauthorized access to the resources of the internet
- Disrupts the intended use of the internet
- Wastes resources (people, capacity, computer) through such actions
- Destroys the integrity of computer-based information
- Compromises the privacy of users

Other Code of Ethics (2)

The Computer Ethics Institutes's Ten Commandments

= avariable

- Thou shalt not use a computer to harm other people.
- Thou shalt not interfere with other people's computer work.
- Thou shalt not snoop around in other people's computer files.
- Thou shalt not use a computer to steal.
- Thou shalt not use a computer to bear false witness.
- Thou shalt not copy proprietary software for which you have not paid.
- Thou shalt not use other people's computer resources without authorization or proper compensation.
- Thou shalt not appropriate other people's intellectual output.
- Thou shalt think about the social consequences of the program you are writing or the system you are designing.
- Thou shalt always use a computer in ways that ensure consideration and respect for your fellow humans.

Other Code of Ethics (3)

IEEE Code and Ethics
https://www.ieee.org/about/corporate/governance/p7-8.html

I. To uphold the highest standards of integrity, responsible behavior, and ethical conduct in professional activities.
   I. Safety, health, public welfare
   II. Educate other people for better understanding of technology.
   III. Avoid conflict of interest
   IV. Avoid unlawful conducts and bribery
   V. Seek, accept and offer honest criticism for work.
   VI. Imporve technical competence
II. To treat all persons fairly and with respect, to not engage in harassment or discrimination, and to avoid injuring others.
III. To strive to ensure this code is upheld by colleagues and co-workers.

Other Code of Ethics (5)

https://ethics.acm.org

1. General Ethical Principles: Contribute to society and human well-being. Avoid harm. Be honest & trustworthy. Be fair & not discriminate. Respect others IPs. Respect privacy. Honor confidentiality.

2. Professional Responsibilities: High quality work. High competence. Respect rules. Accept professional review. Analyse risk. Work in competence area. Foster public awareness. Access resources when authorized. Robust & secure design and implementation.

3. Professional Leadership Principles: Ensure public good. Social responsibilities. Enhance working life quality. Support policy. Help team member grow professionally. Due care for any system change.

4. Compliance With The Code: Uphold & respect the principles of the Code

Other Code of Ethics (6)

Software Engineering Code of Ethics (by IEEE-CS/ACM)
https://www.computer.org/education/code-of-ethics

1. PUBLIC -– Software engineers shall act consistently with the public interest.
2. CLIENT AND EMPLOYER - Software engineers shall act in a manner that is in the best interests of their client and employer consistent with the public interest.
3. PRODUCT - Software engineers shall ensure that their products and related modifications meet the highest professional standards possible.
4. JUDGMENT – Software engineers shall maintain integrity and independence in their professional judgment.
5. MANAGEMENT – Software engineering managers and leaders shall subscribe to and promote an ethical approach to the management of software development and maintenance.
6. PROFESSION– Software engineers shall advance the integrity and reputation of the profession consistent with the public interest.
7. COLLEAGUES – Software engineers shall be fair to and supportive of their colleagues.
8. SELF – Software engineers shall participate in lifelong learning regarding the practice of their profession and shall promote an ethical approach to the practice of the profession.

Common Security Design Principles

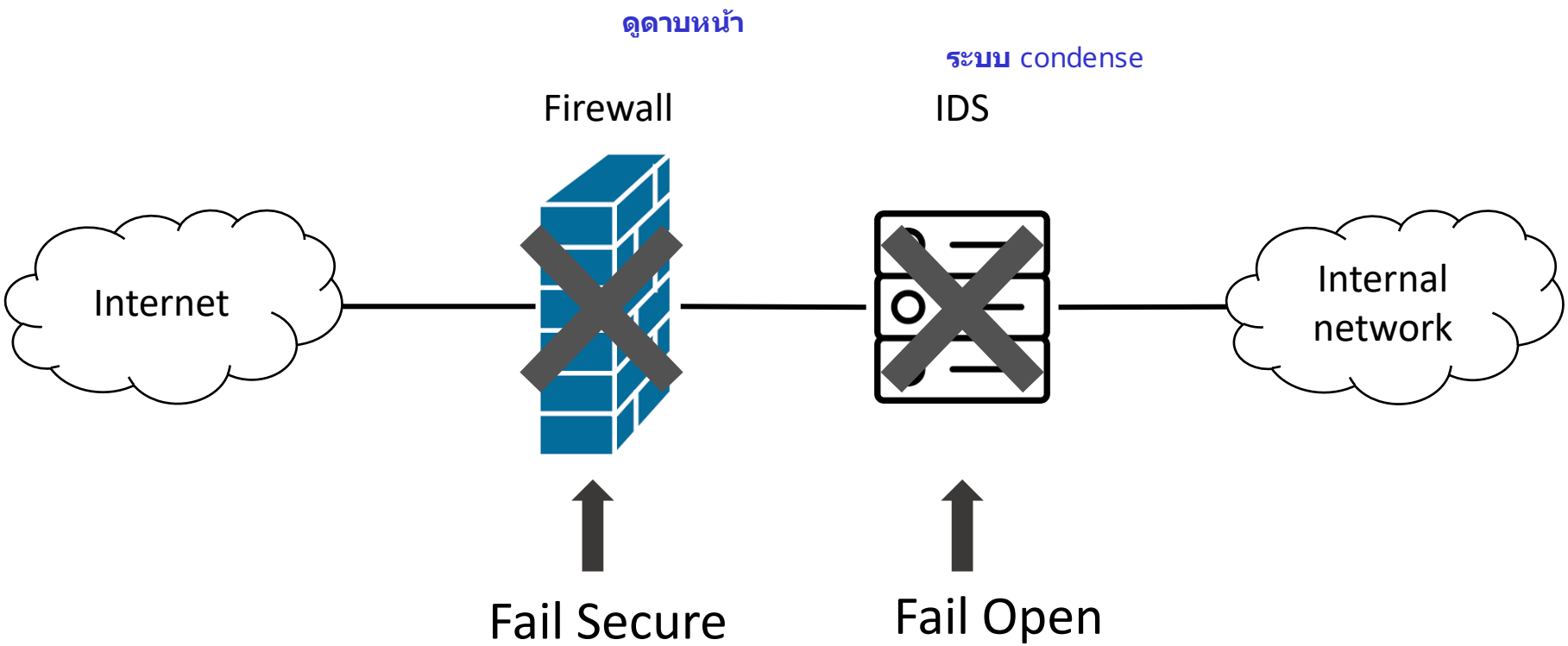
- Fail-secure - if fails, will maintain security.
- Least privilege - minimal privileges given as required to perform one's jobs, similar to need to know
- Least functionality - disabling unnecessary services
- Separation of duties - need more than one person to approve critical action.
- Network separation - separate components so that failure from one cannot affect others, physical isolation & airgaps, network segmentation
- Defense-in-depth -add more layers of controls for the same objectives.

กำหนดสิทธิ์ได้ ว่าอะไรให้ หรือไม่ให้ containing

Fundamental Security Design Principles

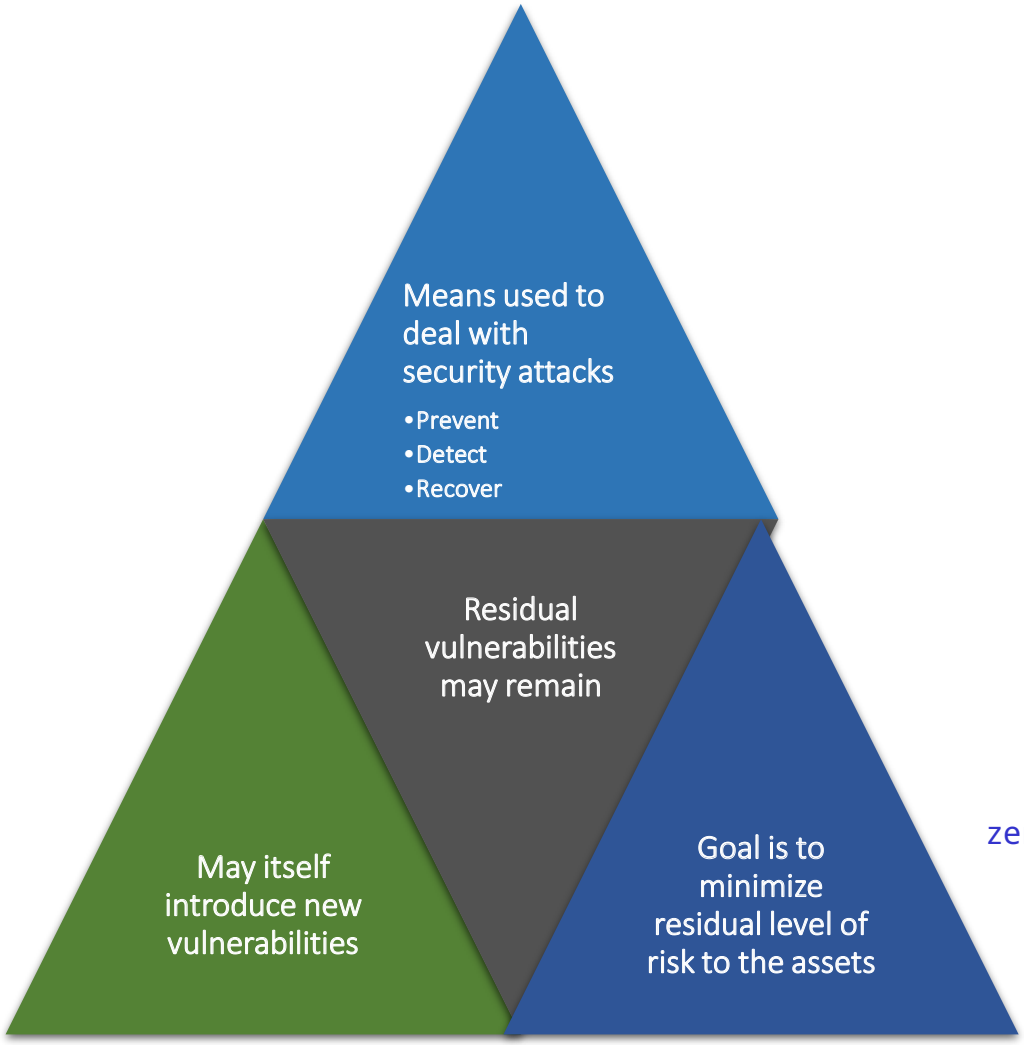
Economy of mechanism	Fail-safe defaults	Complete mediation	Open design
Separation of privilege	Least privilege กำหนดสิทธิ์ต่ำสุด	Least common mechanism	Psychological acceptability
Isolation	Encapsulation	Modularity	Layering
	Least astonishment		

Fail Mode



shell secur

Countermeasure



zero trust

Glossary

exam

Adequate Security

Security commensurate with the risk and the magnitude of harm resulting from the loss, misuse or unauthorized access to or modification of information. Source: OMB Circular A-130

Administrative Controls

Controls implemented through policy and procedures. Examples include access control processes and requiring multiple personnel to conduct a specific operation. Administrative controls in modern environments are often enforced in conjunction with physical and/or technical controls, such as an access-granting policy for new users that requires login and approval by the hiring manager.

Artificial Intelligence

The ability of computers and robots to simulate human intelligence and behavior.

Asset

Anything of value that is owned by an organization. Assets include both tangible items such as information systems and physical property and intangible assets such as intellectual property.

Authentication

Access control process validating that the identity being claimed by a user or entity is known to the system, by comparing one (single-factor or SFA) or more (multi-factor authentication or MFA) factors of identification.

Authorization

The right or a permission that is granted to a system entity to access a system resource. NIST 800-82 Rev.2

Availability

Ensuring timely and reliable access to and use of information by authorized users.

Baseline

A documented, lowest level of security configuration allowed by a standard or organization.

Biometric

Biological characteristics of an individual, such as a fingerprint, hand geometry, voice, or iris patterns.

Bot

Malicious code that acts like a remotely controlled "robot" for an attacker, with other Trojan and worm capabilities.

Classified or Sensitive Information

Information that has been determined to require protection against unauthorized disclosure and is marked to indicate its classified status and classification level when in documentary form.

Confidentiality

The characteristic of data or information when it is not made available or disclosed to unauthorized persons or processes. NIST 800-66

Criticality

A measure of the degree to which an organization depends on the information or information system for the success of a mission or of a business function. NIST SP 800-60 Vol. 1, Rev. 1

Data Integrity

The property that data has not been altered in an unauthorized manner. Data integrity covers data in storage, during processing and while in transit. Source: NIST SP 800-27 Rev A

Encryption

The process and act of converting the message from its plaintext to ciphertext. Sometimes it is also referred to as enciphering. The two terms are sometimes used interchangeably in literature and have similar meanings.

General Data Protection Regulation (GDPR)

In 2016, the European Union passed comprehensive legislation that addresses personal privacy, deeming it an individual human right.

Governance

The process of how an organization is managed; usually includes all aspects of how decisions are made for that organization, such as policies, roles and procedures the organization uses to make those decisions.

Health Insurance Portability and Accountability Act (HIPAA)

This U.S. federal law is the most important healthcare information regulation in the United States. It directs the adoption of national standards for electronic healthcare transactions while protecting the privacy of individual's health information. Other provisions address fraud reduction, protections for individuals with health insurance and a wide range of other healthcare-related activities. Est. 1996.

Impact

The magnitude of harm that could be caused by a threat's exercise of a vulnerability.

Information Security Risk

The potential adverse impacts to an organization's operations (including its mission, functions and image and reputation), assets, individuals, other organizations, and even the nation, which results from the **possibility** of unauthorized access, use, disclosure, disruption, modification or destruction of information and/or information systems.

Institute of Electrical and Electronics Engineers

IEEE is a professional organization that sets standards for telecommunications, computer engineering and similar disciplines.

Integrity

The property of information whereby it is recorded, used and maintained in a way that ensures its completeness, accuracy, internal consistency and usefulness for a stated purpose.

International Organization of Standards (ISO)

The ISO develops voluntary international standards in collaboration with its partners in international standardization, the International Electro-technical Commission (IEC) and the International Telecommunication Union (ITU), particularly in the field of information and communication technologies.

Internet Engineering Task Force (IETF)

The internet standards organization, made up of network designers, operators, vendors and researchers, that defines protocol standards (e.g., IP, TCP, DNS) through a process of collaboration and consensus. Source: NIST SP 1800-16B

Likelihood

The probability that a potential vulnerability may be exercised within the construct of the associated threat environment.

Likelihood of Occurrence

A weighted factor based on a subjective analysis of the probability that a given threat is capable of exploiting a given vulnerability or set of vulnerabilities.

Multi-Factor Authentication

Using two or more distinct instances of the three factors of authentication (something you know, something you have, something you are) for identity verification.

National Institutes of Standards and Technology (NIST)

The NIST is part of the U.S. Department of Commerce and addresses the measurement infrastructure within science and technology efforts within the U.S. federal government. NIST sets standards in a number of areas, including information security within the Computer Security Resource Center of the Computer Security Divisions.

Non-repudiation

The inability to deny taking an action such as creating information, approving information and sending or receiving a message.

Personally Identifiable Information (PII)

The National Institute of Standards and Technology, known as NIST, in its Special Publication 800-122 defines PII as "any information about an individual maintained by an agency, including (1) any information that can be used to distinguish or trace an individual's identity, such as name, Social Security number, date and place of birth, mother's maiden name, or biometric records; and (2) any other information that is linked or linkable to an individual, such as medical, educational, financial and employment information."

Physical Controls

Controls implemented through a tangible mechanism. Examples include walls, fences, guards, locks, etc. In modern organizations, many physical control systems are linked to technical/logical systems, such as badge readers connected to door locks.

Privacy

The right of an individual to control the distribution of information about themselves.

Probability

The chances, or likelihood, that a given threat is capable of exploiting a given vulnerability or a set of vulnerabilities. Source: NIST SP 800-30 Rev. 1

Protected Health Information (PHI)

Information regarding health status, the provision of healthcare or payment for healthcare as defined in HIPAA (Health Insurance Portability and Accountability Act).

Qualitative Risk Analysis

A method for risk analysis that is based on the assignment of a descriptor such as low, medium or high. Source: NISTIR 8286

Quantitative Risk Analysis

A method for risk analysis where numerical values are assigned to both impact and likelihood based on statistical probabilities and monetarized valuation of loss or gain. Source: NISTIR 8286

Risk

A possible event which can have a negative impact upon the organization.

Risk Acceptance

Determining that the potential benefits of a business function outweigh the possible risk impact/likelihood and performing that business function with no other action.

Risk Assessment

The process of identifying and analyzing risks to organizational operations (including mission, functions, image, or reputation), organizational assets, individuals and other organizations. The analysis performed as part of risk management which incorporates threat and vulnerability analyses and considers mitigations provided by security controls planned or in place.

Risk Avoidance

Determining that the impact and/or likelihood of a specific risk is too great to be offset by the potential benefits and not performing a certain business function because of that determination.

Risk Management

The process of identifying, evaluating and controlling threats, including all the phases of risk context (or frame), risk assessment, risk treatment and risk monitoring.

Risk Management Framework

A structured approach used to oversee and manage risk for an enterprise. Source: CNSSI 4009

Risk Mitigation

Putting security controls in place to reduce the possible impact and/or likelihood of a specific risk.

Risk Tolerance

The level of risk an entity is willing to assume in order to achieve a potential desired result. Source: NIST SP 800-32. Risk threshold, risk appetite and acceptable risk are also terms used synonymously with risk tolerance.

Risk Transference

Paying an external party to accept the financial impact of a given risk.

Risk Treatment

The determination of the best way to address an identified risk.

Security Controls

The management, operational and technical controls (i.e., safeguards or countermeasures) prescribed for an information system to protect the confidentiality, integrity and availability of the system and its information. Source: FIPS PUB 199

Sensitivity

A measure of the importance assigned to information by its owner, for the purpose of denoting its need for protection. Source: NIST SP 800-60 Vol 1 Rev 1

Single-Factor Authentication

Use of just one of the three available factors (something you know, something you have, something you are) to carry out the authentication process being requested.

State

The condition an entity is in at a point in time.

System Integrity

The quality that a system has when it performs its intended function in an unimpaired manner, free from unauthorized manipulation of the system, whether intentional or accidental. Source: NIST SP 800-27 Rev. A

Technical Controls

Security controls (i.e., safeguards or countermeasures) for an information system that are primarily implemented and executed by the information system through mechanisms contained in the hardware, software or firmware components of the system.

Threat

Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image or reputation), organizational assets, individuals, other organizations or the nation through an information system via unauthorized access, destruction, disclosure, modification of information and/or denial of service. Source: NIST SP 800-30 Rev 1

Threat Actor

An individual or a group that attempts to exploit vulnerabilities to cause or force a threat to occur.

Threat Vector

The means by which a threat actor carries out their objectives.

Token

A physical object a user possesses and controls that is used to authenticate the user's identity. NISTIR 7711

Vulnerability

Weakness in an information system, system security procedures, internal controls or implementation that could be exploited by a threat source. Source: NIST SP 800-30 Rev 1

End of Security Concepts
Part II